보안 검토: 분석 보고서 반영안

0. 한눈에 보기

항목	내용
검토 대상	사용자가 제공한 '개발 기획안 2 번(올인원 육아 앱 서비스) 분석 보고서'의 내용과 우리 8 주 계획(07)
검토 범위	**설계 수준**의 보안 위험과 대책. 코드, 인프라 설정, 실제 서비스는 확인하지 못했다
가장 큰 위험	① 아기·육아 기록·**음성**을 다루는 **아동 개인정보** ② Supabase **RLS(행 단위 보안) 설정 실수**로 인한 다른 가족 데이터 노출 ③ 외부 LLM·TTS 로의 데이터 전송과 **API 키 유출** ④ AI 가 만든 콘텐츠가 승인 없이 아이에게 노출
법규	개인정보 보호법, 의료기기 규제, 스토어 키즈·가족 정책은 **법무·전문가 확인이 필요**하다. 이 문서의 법규 내용은 분석 보고서에 인용된 내용을 옮긴 것이다
우선순위	**P0**(출시 전 반드시), **P1**(출시 전 권장), **P2**(출시 후 또는 기능 확대 시)

1. 분석 보고서에서 보안에 영향이 큰 내용

분석 보고서의 내용	보안 관점의 의미
육아 기록(수유·수면·기저귀)과 아기 프로필을 저장 (children, child_guardians, care_logs)	건강과 관련될 수 있는 **민감 정보**가 쌓인다. 우리 8 주안(07)에는 육아 기록이 없지만 분석 안을 따르면 위험이 커진다
울음소리 녹음을 분석 (버튼 녹음, 서버 분석, 원본 비저장 권장)	**음성 데이터**가 서버로 전송된다. 동의·삭제·최소 보관이 핵심이다
Flutter 앱이 Supabase Auth 를 **직접** 이용할 수도 있고, 보호 데이터는 API 경유	데이터에 접근하는 경로가 **두 개**가 되어 권한 검사가 한쪽에서 빠질 수 있다
FastAPI 가 JWT 를 검증하고 권한에 맞는 작업만 처리	JWT 검증 항목(서명, 만료, 발급자, 대상)과 소유권 검사를 정확히 구현해야 한다
RLS 를 child_guardians 기준으로 설계	RLS 는 마지막 방어선이다. **설정 누락이나 정책 오류가 곧 데이터 유출**이다
Redis + Celery 로 동화 생성·TTS 같은 장시간 작업 처리	큐 서버의 외부 노출, 작업 인자에 개인정보 포함, 작업 위조 위험
외부 LLM(OpenAI 등)과 Typecast API 사용	외부 전송 데이터, **API 키**, 사용량 폭증(비용 공격), 제공자 약관(데이터 보관·학습 사용)
Supabase Storage(동화 오디오·이미지) + S3 백업	버킷 공개 범위, 서명 URL, 백업의 암호화·접근 통제. 분석도 DB 백업에 Storage 파일은 포함되지 않는다고 언급

분석 보고서의 내용	보안 관점의 의미
관리자 웹(Next.js)으로 검수·게시	**가장 강한 권한**을 가진 화면이다. 관리자 계정 탈취가 곧 아이에게 보이는 콘텐츠 조작이다
부모 승인·사람 검수 후 공개, 유사도 검사	승인 절차가 **서버에서 강제**되어야 우회되지 않는다
한국 개인정보 보호법 제 22 조의 2(만 14 세 미만 아동)와 법정대리인 동의	보호자 계정 구조여도 **아동 정보의 보호 의무**는 남는다 (분석 보고서의 인용, 전문가 확인 필요)
온프레미스 운영 후 Supabase 이관(기획서 첫 페이지의 구상)	분석은 개발 도중 이전을 권장하지 않았다. 이전 과정에서 **데이터 유출·설정 불일치** 위험이 생긴다

2. 데이터 분류와 최소 수집 (P0)

데이터	민감도	권장 처리
보호자 계정(소셜 로그인 식별자, 이메일)	중간	필요한 항목만 수집. 소셜 로그인 제공자가 주는 정보 중 쓰지 않는 항목은 저장하지 않는다
아이 프로필	**높음**	**별칭과 생년월만**(기획서 원칙 유지). 실명, 사진, 정확한 생일은 받지 않는다
육아 기록(수유·수면·기저귀 등)	**높음**	도입한다면 보호자만 접근, 보존 기간·삭제 기능 명시. 건강 정보처럼 취급
울음 녹음 원본	**매우 높음**	**저장하지 않고 분석 후 즉시 삭제**가 기본. 학습 재사용은 별도 동의·철회 절차 후에만
울음 분석 결과	높음	시각, 모델 버전, 결과, 불확실성만 저장
취향·재생 이력	중간	콘텐츠 ID 와 태그만 저장, 부모가 초기화 가능
생성 요청·생성 동화	중간	요청에 아이 이름·개인정보가 들어가지 않게 입력을 선택형으로 제한
로그·크래시 리포트	중간	개인정보 마스킹, 아이 정보 전송 금지

점검: 수집 항목 표를 만들어 “이 정보가 없으면 기능이 안 되는가?”를 항목마다 확인한다. 아니면 수집하지 않는다.

3. 인증•인가 (P0)

위험	대책
다른 가족의 아이·기록을 조회하는 접근(IDOR)	모든 API 에서 요청한 child_id 가 **로그인한 보호자의 아이인지** 서버에서 확인한다. child_guardians 관계로 판단

위험	대책
RLS 미적용·정책 오류	**모든 테이블에 RLS 를 켜고** 기본 거부로 시작한다. 정책마다 "다른 가족 계정으로 접근 시도" 자동 테스트를 만든다. RLS 가 꺼진 테이블은 공개 키로 접근될 수 있으므로 설정에 따라 즉시 노출될 수 있다
접근 경로가 둘(직접 Supabase, API)	둘 중 하나로 **원칙을 정한다**. 권장: 민감 데이터(아이, 기록, 생성 요청)는 **API 경유만** 허용하고, 직접 접근 경로는 RLS 로 막는다. 어느 쪽이든 RLS 는 유지한다(이중 방어)
서비스 롤 키(관리자 키) 노출	**앱·웹 클라이언트에 절대 넣지 않는다.** 서버 전용 비밀로 보관한다. 이 키는 RLS 를 우회한다
JWT 위조·재사용	FastAPI 에서 서명, 만료, 발급자, 대상(audience)을 검증하고 비밀·공개키를 안전하게 보관한다
토큰 탈취	앱에서는 Keychain·Keystore 같은 보안 저장소에 저장한다. 로그아웃 시 삭제, 짧은 만료와 갱신 정책
소셜 로그인 설정 오류	리다이렉트 URI 를 정확히 등록하고 와일드카드를 쓰지 않는다. 제공자별 콘솔 계정에 MFA 를 켠다
관리자 권한 과다	관리자 역할을 **작성자·검수자·운영자**로 나누고 최소 권한을 준다. 제작자가 자기 콘텐츠를 승인하지 못하게 한다

4. 서버·API 보안 (P0~P1)

항목	대책	우선순위
입력 검증	요청 스키마(Pydantic 등)로 형식·길이·범위를 검증한다. DB 접근은 ORM 또는 매개변수 쿼리만 사용	P0
속도 제한	로그인, 생성 요청, 음성 업로드, 신고에 요청 제한. 비용이 드는 API(LLM·TTS)는 사용자·일 단위 한도	P0
파일 업로드(음성)	크기·길이·형식 제한, 서버에서 형식 확인, 임시 저장 후 분석 끝나면 삭제	P0
오류 응답	내부 정보(스택, 쿼리)를 응답에 싣지 않는다	P1
CORS·헤더	허용 출처를 명시, HTTPS 강제, 보안 헤더 설정	P1
로그	인증 실패, 권한 거부, 비정상 요청 기록. 개인정보는 마스킹	P1
전송 구간	모든 통신 TLS. 평문 HTTP 비활	P0

항목	대책	우선순위
	성화	
의존성	취약점 점검(Dependabot 등)과 락파일 고정	P1

5. Supabase·저장소 (P0~P1)

위험	대책
공개 버킷에 비공개 파일 노출	버킷을 **공개/비공개로 구분**한다. 공개는 검수 완료된 동화·동요 파일만. 생성 요청·음성·개인 데이터는 비공개
유료·비공개 파일의 URL 공유	서명 URL(만료 시간 짧게)로 제공한다. 오프라인 저장을 위한 다운로드도 인증된 요청으로만 발급
승인 전 콘텐츠 접근	PUBLISHED 가 아닌 콘텐츠는 **재생 URL 을 발급하지 않는다**(서버 강제). 앱 화면에서 숨기는 것만으로는 부족하다
개발·운영 환경 혼용	개발·스테이징·운영을 **분리**하고, 운영 DB 는 직접 수정하지 않고 마이그레이션으로만 변경한다. 로컬 개발 스택을 외부에 노출하지 않는다
대시보드 계정 탈취	Supabase·클라우드·GitHub 계정에 MFA 를 켜고 소유자를 최소화한다
업로드 악용	업로드 크기·형식 제한, 콘텐츠 업로드는 관리자 권한만
온프레미스→Supabase 이관	이관 시 데이터 암호화 전송, 이전 후 원본 삭제 확인, 키·비밀번호 교체. 가능하면 개발 도중 이관을 피한다

6. 비밀키·외부 서비스 (P0)

위험	대책
LLM·Typecast·S3 키가 앱에 포함	**앱 번들에 키를 넣지 않는다**(앱은 분해해서 읽을 수 있다). 모든 외부 호출은 서버를 거친다. Typecast 공식 문서도 키를 백엔드에서 쓰도록 안내한다
저장소에 키 커밋	.env 를 커밋하지 않고, 저장소 비밀 스캔(GitHub secret scanning)을 켠다. 이미 노출됐다면 즉시 폐기·재발급
키 하나의 권한 과다	키·계정별 최소 권한, 환경별 키 분리
사용량·비용 폭증	제공자 측 사용 한도와 알림 설정, 서버 측 일 한도
제공자 약관	LLM·TTS 제공자가 입력 데이터를 **보관하거나 학습에 쓰는지** 확인한다. 아이 이름과 개인정보를 프롬프트에 넣지 않는다
국외 이전	LLM·TTS·클라우드 리전이 국외인 경우 개인정보처리방침에 고지하고 법적 요건을 확인한다(법무 확

위험	대책
	인 필요)
키 교체	정기 교체와 유출 시 즉시 교체 절차를 문서화

7. AI 기능 보안 (P0~P1)

위험	설명	대책
프롬프트 주입(직접)	사용자가 입력으로 모델 지시를 바꾸려 한다	입력을 **선택형**으로 제한(자유 입력 금지), 입력 길이·형식 검증, 시스템 지시와 사용자 입력 분리
프롬프트 주입(간접)	RAG 로 검색된 문서 안의 문장이 지시처럼 작동한다	코퍼스는 관리자가 검수한 문서만 허용, 검색 결과를 "참고 자료"로만 전달하고 지시로 취급하지 않도록 명시, 출력 검사
코퍼스 오염	악의적·저작권 문제 문서가 코퍼스에 들어간다	코퍼스 등록은 관리자 권한과 출처·라이선스 기록을 필수로 하고, 변경 이력을 남긴다
부적절한 출력	무서운 내용, 개인정보, 브랜드, 건강 정보 단정	자동 안전 검사 + 사람 승인 + 신고 시 즉시 비공개. 승인 상태는 서버가 강제
원문 복제	저작권 문제, 코퍼스 유출	원문 유사도 검사, 코퍼스 원문 전체를 사용자에게 반환하지 않음
데이터 유출	프롬프트·로그에 개인정보가 섞인다	개인정보를 모델에 보내지 않고, 로그에서 마스킹
자원 남용	생성·TTS 요청으로 비용 폭증	사용자별 한도, 작업 큐 길이 제한, 비정상 사용 감지
건강 정보 오류	이유식·질병 정보를 AI 가 지어낸다	검수된 자료만 사용(분석 보고서와 같은 권고), 면책 문구, 소아과 상담 안내

8. 울음 음성 기능 (P0, 도입 시)

위험	대책
상시 녹음·무단 녹음	**보호자가 버튼을 눌러 짧게 녹음**하는 방식만 허용(분석 보고서의 권장과 일치). 24 시간 감시 기능은 제외
동의 없는 수집	마이크 권한 요청 문구와 앱 내 동의 화면에 수집 목적·보관·삭제를 명시
음성 원본 보관	분석 후 **즉시 삭제**, 서버 임시 저장은 암호화 + 짧은 보관
학습 재사용	별도 동의·철회 절차와 법적 근거 확인 후에만. 철회 시 학습 데이터에서 제외하는 방법을 정한다
오탐·미탐으로 인한 안전 문제	"진단이 아닙니다" 안내, 확신이 낮으면 '판단 불

위험	대책
	가', 위험 판단 표현 금지
서버 전송	TLS, 인증된 요청만. 온디바이스 추론은 서버 전송 자체를 없애므로 보안상 유리
규제	의료기기 해당 여부와 스토어 심사 기준을 사전에 확인(법무·규제 전문가)

9. 관리자 웹 (P0)

위험	대책
관리자 계정 탈취	MFA 필수, 강한 비밀번호 정책, 로그인 시도 제한
권한 과다	역할 분리(작성자·검수자·운영자), 제작자와 승인자 분리
감사 불가	콘텐츠 변경·승인·반려·삭제를 **감사 로그**로 남긴다(누가, 언제, 무엇을)
웹 취약점	XSS(콘텐츠·신고 텍스트 출력 이스케이프), CSRF, 세션 관리, 파일 업로드 검증
접근 범위	관리자 화면은 별도 도메인과 접근 제한(허용 IP 또는 VPN 은 선택)

10. Redis·Celery·백업 (P0~P1)

항목	위험	대책
Redis	인증 없이 외부에 노출	비밀번호·TLS, 내부 네트워크 전용, 외부 포트 차단
작업 큐	작업 위조, 개인정보가 작업 인자에 포함	작업에는 ID 만 담고 데이터는 DB 에서 조회, 작업 인자 검증
DB 백업	백업에도 개인정보가 있다	암호화, 접근 제한, 보존 기간 설정. **삭제 요청이 백업에도 반영**되도록 보존 기간을 정한다
S3 백업 버킷	공개 설정 실수	**비공개**, 서버측 암호화, 최소 권한 키, 버전 관리, 수명 주기
Storage 파일	DB 백업에 포함되지 않음(분석 보고서도 언급)	파일은 **별도로 백업**한다
복구	복구가 안 되는 백업	**실제 복원 테스트**를 1 회 이상. 복구 목표 시간·시점을 문서화

11. 앱과 개발 파이프라인 (P1)

항목	대책
앱 로컬 저장	토큰은 보안 저장소, 오프라인 콘텐츠는 비민감 데이터만 저장
외부 링크·광고·분석 SDK	**외부 링크와 광고를 넣지 않는다**(기획서 '안심 약속'과 일치). 분석·크래시 SDK 는 개인정보 전송 여

항목	대책
	부를 확인(Sentry 포함)하고 아이 정보를 보내지 않는다. 스토어 키즈·가족 정책의 SDK 제한은 확인 필요
딥링크	링크 검증, 민감 동작은 인증 확인
서드파티 패키지	최소화, 버전 고정, 취약점 점검
GitHub	브랜치 보호, 리뷰 필수, 시크릿 스캔, Actions 의 비밀값 최소 노출
서명 키	Android 키스토어, Apple 인증서는 분실·유출 대비 안전한 곳에 이중 보관
빌드	운영 키가 개발 빌드에 들어가지 않도록 환경 분리

12. 사고 대응과 모니터링 (P1)

항목	내용
로그·알림	인증 실패 급증, 권한 거부, 비용 급증, 서버 오류에 알림 설정
대응 절차	유출 의심 시 **키 폐기 → 접근 차단 → 범위 확인 → 이용자·기관 통지** 순서를 문서화. 통지 기한과 대상은 법무 확인
담당자	보안 책임자 1 명과 대리인을 정한다
복구	백업 복원 훈련, 연락망

13. 법규·정책 확인 (전문가 확인 필요)

항목	내용
아동 개인정보	분석 보고서는 만 14 세 미만 아동 정보에 법정대리인 동의가 필요하다고 인용했다. **보호자 계정 구조여도 의무는 남는다**. 개인정보처리방침과 동의 기록 보관, 열람·삭제 요청 처리 절차가 필요하다
수집·이용	수집 항목, 목적, 보관 기간, 국외 이전, 처리 위탁(LLM·TTS·클라우드)을 개인정보처리방침에 명시
의료기기	울음 분석을 진단·치료 목적으로 표방하면 규제 대상이 될 수 있다. '감지 알림·참고용'으로 한정하고 문구를 검토
스토어 정책	Apple 키즈, Google Families 정책의 광고·분석·생성형 AI 콘텐츠·로그인 요건 확인
생성 콘텐츠	AI 생성물 표시, 저작권·라이선스 기록, TTS 음원 저장·재배포 조건(Typecast 약관) 확인

14. 8 주 일정에 넣는 보안 작업

주	작업	담당(역할)
1	데이터 분류와 수집 항목 확정,	R1, R4

주	작업	담당(역할)
	키·비밀 관리 규칙, 환경 분리, 인증 방식 결정(직접/API 경유), 계정 MFA	
2	인증·JWT 검증 구현, **RLS 정책과 접근 테스트 자동화**	R4
3~4	입력 검증, 속도 제한, 스토리지 버킷 구분, 서명 URL, 관리자 역할 분리와 감사 로그	R4
5	AI 입력 제한, 프롬프트 주입 대응, 안전 검사, 승인 게이트 서버 강제, 개인정보처리방침 초안	R4, R1
6	비용 한도·알림, 로그 마스킹, 의존성·시크릿 스캔 정착	R4
7	**보안 점검**: 권한 침투 테스트(다른 가족 계정), 백업 복원 테스트, 키 노출 점검, 스토어 정책 점검	R1, R4 + 전원
8	출시 전 체크리스트 최종 확인, 사고 대응 연락망	R1

15. 출시 전 보안 체크리스트

P0 (반드시) - [ ] 모든 테이블에 RLS 가 켜져 있고, 다른 가족 계정으로 접근이 거부되는 테스트를 통과 - [ ] 서비스 롤 키, LLM·TTS·S3 키가 앱·저장소·로그에 없다 - [ ] 민감 데이터 접근 경로가 하나로 정리되어 있다(API 경유 또는 RLS 전용) - [ ] 승인되지 않은 콘텐츠의 재생 URL 이 발급되지 않는다 - [ ] 아이 정보는 별칭·생년월만 수집한다 - [ ] 음성 원본이 저장되지 않는다(도입 시) - [ ] 외부 전송 데이터에 아이 개인정보가 없다 - [ ] 전 구간 TLS, 관리자 MFA, 환경 분리 - [ ] 개인정보처리방침과 동의 화면이 있다

P1 (권장) - [ ] 속도 제한과 비용 한도·알림 - [ ] 관리자 감사 로그와 역할 분리 - [ ] 백업 암호화와 복원 테스트 - [ ] 의존성·시크릿 스캔, 브랜치 보호 - [ ] 사고 대응 절차와 담당자

P2 (기능 확대 시) - 커뮤니티·채팅(2 차) 도입 시 신고·차단·모더레이션, 아동 노출 통제 - 결제·구독 도입 시 결제 정보 처리 정책 - 제휴 상품 추천 도입 시 광고 표시와 제휴 데이터 접근 통제

16. 분석 보고서에 대한 보안 관점의 보완 의견

분석 보고서의 내용	보완 의견
Flutter 앱이 Supabase Auth 를 직접 이용 + 보호 데이터는 API 경유	접근 경로를 하나로 정하고, 다른 경로는 RLS 로 막는다(3 장)
Redis 는 필요해질 때 도입	도입 시 외부 노출 차단과 인증 설정을 함께 적용한다(10 장)
육아 기록(care_logs) 저장	건강 정보에 준하는 보호와 삭제 기능이 필요하다. 우리 8 주안(07)처럼 **초기에는 기록 기능을 넣지 않는 것**도 보안상 유리하다
외부 LLM 으로 동화 초안 생성	입력을 선택형으로 제한하고 아이 정보를 보내지

분석 보고서의 내용	보완 의견
	않는다. 제공자의 데이터 보관·학습 사용 조건을 확인한다
음성은 서버에서 짧게 분석, 원본 비저장	옳은 방향이다. 서버 임시 파일의 암호화·삭제 시점, 로그에 음성 메타데이터가 남는지도 점검한다
S3 백업	비공개·암호화·최소 권한, Storage 파일 별도 백업, 삭제 요청 반영 정책이 필요하다
2 개월 시연 중심	시연용이라도 **실제 이용자 데이터를 넣기 전**에 P0 항목은 끝내야 한다. 시연에는 가짜 데이터만 쓴다

17. 이 문서의 한계

- 분석 보고서는 설계 문서이므로 **코드와 설정을 검토한 것이 아니다**. 구현 후 실제 취약점 점검(권한 테스트, 의존성 점검, 설정 검토)이 필요하다.
- 법규(개인정보 보호법, 의료기기, 국외 이전, 스토어 정책)는 제가 원문을 확인하지 않았고 전문가 확인이 필요하다.
- Supabase, Typecast, 스토어 정책의 세부 동작은 공식 문서로 재확인해야 한다.
- 위 우선순위는 제안이며, 팀의 일정과 위험 수용 범위에 맞춰 조정한다.